



МИНОБРНАУКИ РОССИИ

Федеральное государственное бюджетное образовательное учреждение
высшего образования

«МИРЭА – Российский технологический университет»

РТУ МИРЭА

ЛЕКЦИОННЫЕ МАТЕРИАЛЫ

Системы мониторинга и управления инцидентами информационной безопасности

	<i>(наименование дисциплины (модуля) в соответствии с учебным планом)</i>
Уровень	
	<i>(бакалавриат, магистратура, специалитет)</i>
Форма обучения	
	<i>(очная, очно-заочная, заочная)</i>
Направление(-я) подготовки	
	<i>(код(-ы) и наименование(-я))</i>
Институт	Институт кибербезопасности и цифровых технологий
	<i>(полное и краткое наименование)</i>
Кафедра	Интеллектуальные системы информационной безопасности
	<i>(полное и краткое наименование кафедры, реализующей дисциплину (модуль))</i>
Лектор	к.т.н., Урасков Юрий Леонидович
	<i>(сокращенно – ученая степень, ученое звание; полностью – ФИО)</i>
Используются в данной редакции с учебного года	2022/23
	<i>(учебный год цифрами)</i>
Проверено и согласовано « ____ » _____ 20__ г.	
	<i>(подпись директора Института/Филиала с расшифровкой)</i>

Москва 2022 г.

Лекция 3. Классификации уязвимостей. Распределенные системы обнаружения вторжений dIDS. SIEM-системы.

Уязвимость (vulnerability) – любая характеристика информационной системы, использование которой нарушителем может привести к реализации угрозы. При этом неважно, целенаправленно используется уязвимость или это происходит ненамеренно.

Под **дефектом безопасности (weakness, bug)** будем понимать недостаток создания ПО, потенциально влияющий на степень безопасности информации. В таком случае эксплуатируемый дефект безопасности представляет собой **уязвимость (vulnerability)**, реализация которой составляет угрозу ИБ.

Для реализации уязвимости необходимо наличие **субъекта**, воздействующего на информационную систему и способного эксплуатировать уязвимость.

В настоящее время можно встретить ряд как простых, так и сложных иерархических классификаций в области программной безопасности, которые можно разделить на следующие:

- классификации угроз и атак;
- классификации вредоносных программ;
- классификации и реестры уязвимостей.

Классификации и реестры уязвимостей

Исторически реестры уязвимостей были обусловлены потребностью в регулярном распространении бюллетеней и сводок о найденных уязвимостях для каждого типа и версии программных продуктов и сред. Такие реестры поддерживаются как крупными разработчиками ПО (например Adobe, Microsoft, RedHat), так и различными ассоциациями (US-CERT, Open Information Security Foundation).

Последние создали ряд реестров, группирующих в единой системе идентификаторов (например, CVE-ID) уязвимости ПО различных разработчиков.

Таблица 1. Примеры реестров уязвимостей

Вид	Примеры	Особенности
Классификации вредоносного программного обеспечения	<i>Mitre MAEC (Malware Attribute Enumeration and Characterization)</i> – перечень и характеристики признаков вредоносного ПО	Язык для описания вредоносного ПО, учитывающий признаки поведения, тип атаки и т. п.
	<i>Kaspersky Classification</i> – классификация Лаборатории Касперского	Классификация вредоносного ПО по способам воздействия
	<i>Symantec Classification</i> – классификация фирмы Symantec	Классификация обнаруженного вредоносного ПО
Реестры и классификации уязвимостей программных систем	<i>MITRE CVE (Common Vulnerabilities and Exposures)</i> – общие уязвимости и «незащищенности»	База данных известных уязвимостей
	<i>NVD (National Vulnerability Database)</i> – национальная база уязвимостей США	База уязвимостей, использующая идентификаторы CVE
	<i>CERT Vulnerability Notes Database</i> – база уязвимостей	Описание найденных уязвимостей и способов их обнаружения
	Бюллетени разработчиков: · Microsoft Bulletin ID · Exploit-DB	Сводки найденных уязвимостей

Классификации угроз безопасности и компьютерных атак на ресурсы системы	<i>OWASP Top Ten</i> – 10 самых распространенных угроз для веб-приложений	Десять наиболее актуальных классов угроз, связанных с уязвимостями web-приложений за последний год
	<i>MITRE CAPEC (Common Attack Pattern Enumeration and Classification)</i> – перечень и классификация распространенных типов атак	Всесторонняя классификация типов атак
	<i>WASC Threat Classification 2.0</i> – классификация угроз Консорциума безопасности web-приложений	Классификация изъянов, угроз web-безопасности, нацеленная на практическое применение

Из таблицы 1 видно, что в настоящее время известно достаточно большое количество классификаций в области ИБ, в основном они ориентированы на конкретные задачи, будь то сетевые атаки, уязвимости операционных систем или некорректности программирования.

Среди рассмотренных таксономий лучшим, с точки зрения разработчика, является реестр CWE (по показателям полноты, всесторонности классификации, наличия подробных описаний с примерами кода), а с точки зрения администратора, самой эффективной представляется таксономия CVE (по показателям объема записей, оперативности обновления).

NVD (National Vulnerability Database) – национальная база данных уязвимостей правительства США предназначена для автоматизации управления уязвимостями и их соответствием программному обеспечению, в составе: <https://nvd.nist.gov>

CVE (Common Vulnerabilities and Exposures) – список известных уязвимостей, имеющий строгое структурирование по описательным критериям; <http://cve.mitre.org/cve/index.html>

CWE (Common Weakness Enumeration) – словарь категорий уязвимостей в программных продуктах; <http://cwe.mitre.org>

CPE (Common Platform Enumeration) – система идентификации программных продуктов;

CVSS (Common Vulnerability Scoring System) –система оценки степени опасности различных уязвимостей;

<http://www.kb.cert.org/vuls> – база данных уязвимостей, которую ведет подразделение CERT Division института Software Engineering Institute (SEI)

<https://www.microsoft.com/en-us/msrc> – сайт центра Microsoft Security Response Center (MSRC). В MSRC изучаются все отчеты об уязвимостях системы безопасности, которым подвержены продукты и службы Майкрософт. Эти документы выпускаются в рамках постоянных усилий, направленных на то, чтобы помочь пользователям управлять рисками безопасности и поддерживать защиту своих систем.

<https://helpx.adobe.com/ru/security.html> – бюллетени по безопасности и рекомендации. На этой странице размещена информация об уязвимостях защиты, которым могут быть подвержены некоторые версии продуктов Adobe.

Реестры уязвимостей некоторых популярных дистрибутивов ОС Linux:

<https://access.redhat.com/security/>

<http://www.debian.org/security/>

<http://www.ubuntu.com/usn/>

OWASP — это открытое сообщество экспертов, разрабатывающих методики, стандарты, рекомендации и средства обеспечения безопасности Web-приложений.

https://www.owasp.org/index.php/Main_Page

Открытый проект обеспечения безопасности веб-приложений. Сообщество OWASP включает в себя корпорации, образовательные организации и частных лиц со всего мира. Сообщество работает над созданием статей, учебных пособий, документации, инструментов и технологий, находящихся в свободном доступе.

Проект OWASP не связан ни с одной компанией, занимающейся разработкой технологий, и в целом поддерживает грамотное использование технологий безопасности. OWASP избегает аффилирования, так как полагает, что свобода от влияния со стороны других организаций может облегчить распространение беспристрастной, полезной и дешевой информации о безопасности приложений.

<http://ovaldb.ru.altx-soft.ru/About.aspx> русскоязычный репозиторий языка OVAL (Open Vulnerability and Assessment Language)

<http://bdu.fstec.ru/ubi/threat> - Банк данных угроз безопасности информации ФСТЭК России.

Системы обнаружения вторжений (атак). (IDS - Intrusion Detection Systems)

Атака на информационную систему - событие или совокупность событий, которые применительно к каждому отдельно взятому объекту должны рассматриваться в качестве попыток совершения информационного воздействия противоправного или деструктивного характера.

Обнаружение атак - это процесс оценки подозрительных действий в защищаемой сети, который реализуется либо посредством анализа журналов регистрации операционной системы и приложений либо сетевого трафика.

Цель обнаружения атак - выявить признаки атак либо во время их, либо постфактум. В качестве таких признаков могут выступать:

- повтор определенных событий;
- неправильные или несоответствующие текущей ситуации команды;
- использование уязвимостей;
- несоответствующие параметры сетевого трафика;
- непредвиденные атрибуты;
- необъяснимые проблемы;
- дополнительные знания о нарушениях.

Классификация систем обнаружения атак по принципу реализации

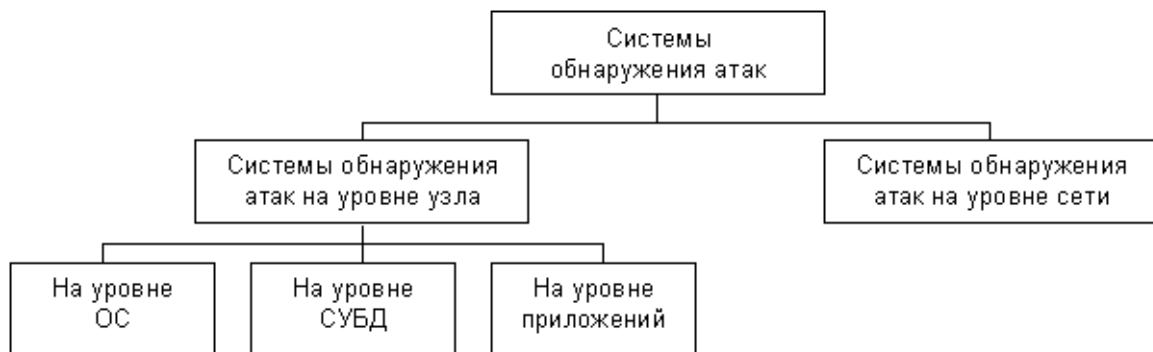


Рисунок 1 – Обобщенная классификация систем обнаружения атак

СОА на уровне узла – осуществляют мониторинг активности одного узла в сети.

СОА на уровне сети – объектом мониторинга является сетевой сегмент.

Существует два подхода к обнаружению атак:

Обнаружение злоупотреблений – в данном подходе СОА осуществляют поиск шаблонов известных атак в сетевом трафике или высокоуровневых данных.

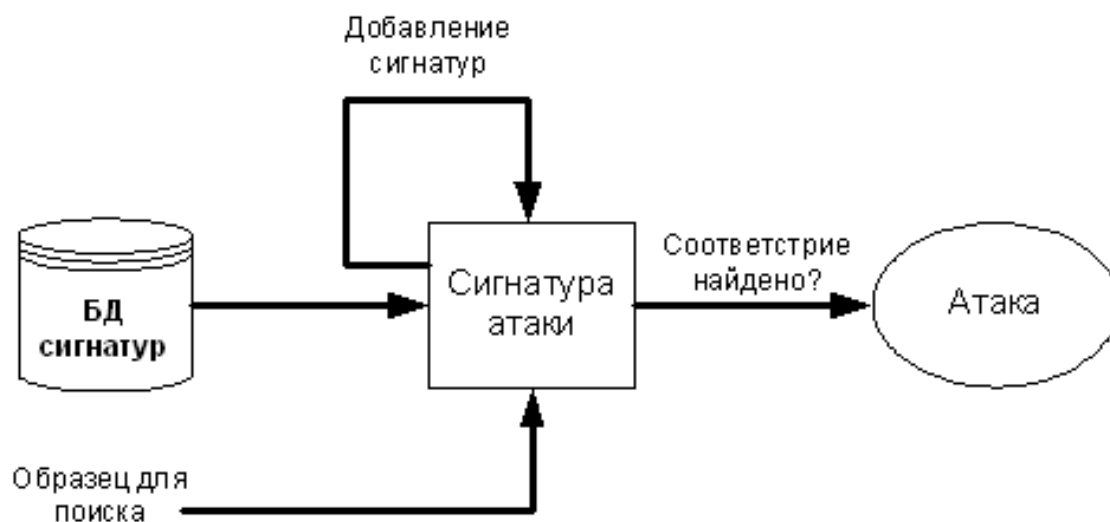


Рисунок 2 – Обобщенная архитектура системы обнаружения злоупотреблений

Обнаружение аномалий – в данном подходе СОА обладают профилем нормальной активности системы и детектируют отклонения от него.

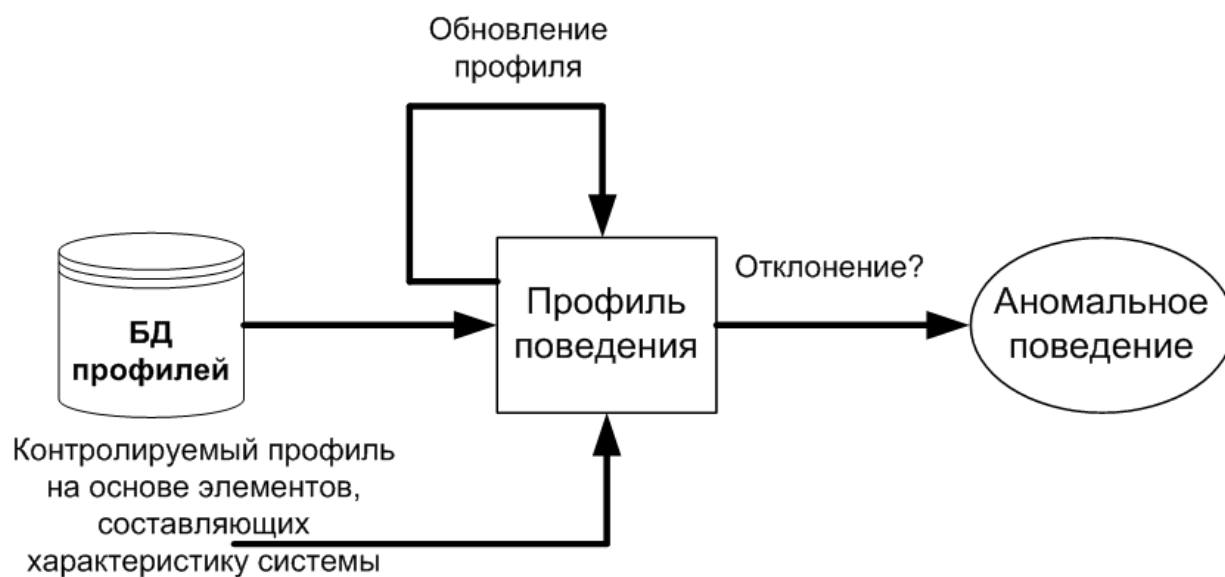


Рисунок 3 – Обобщенная архитектура системы обнаружения аномалий

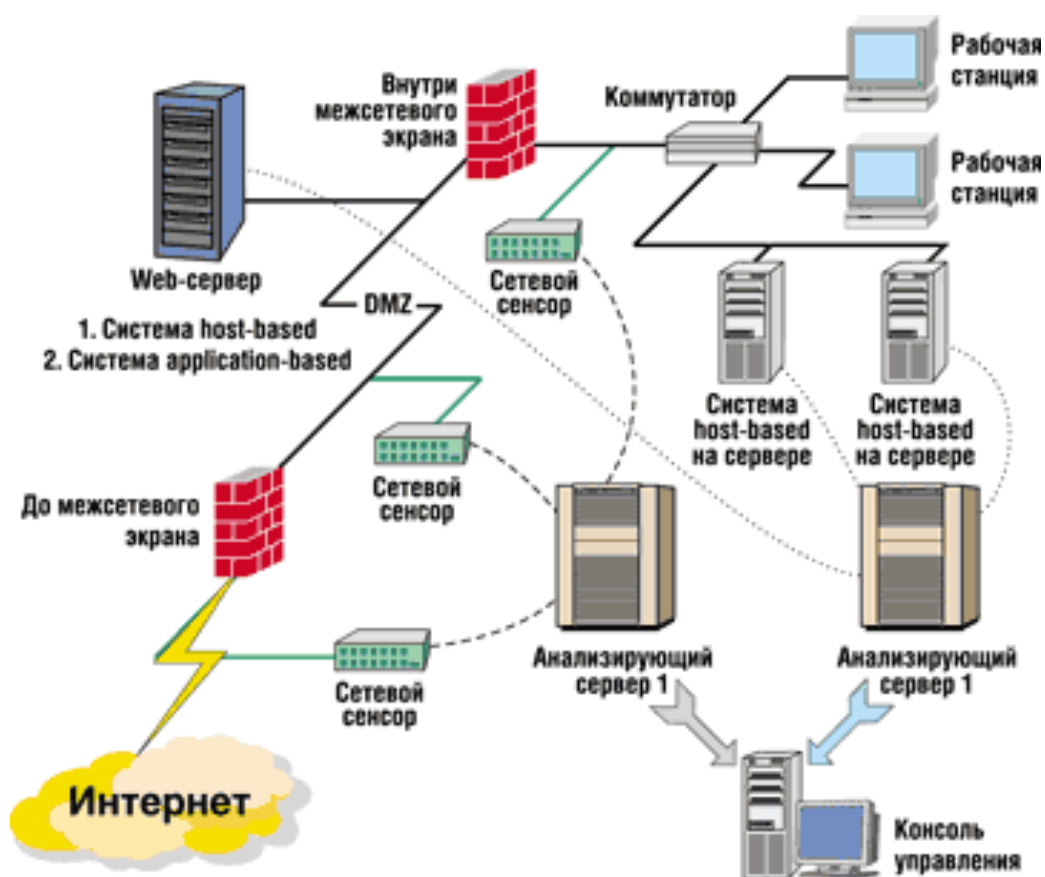


Рисунок 4 – Общая схема функционирования dIDS.

Существуют также системы, называемые distributed IDS (dIDS). dIDS состоит из множества IDS, которые расположены в различных участках большой сети и связаны между собой и с центральным управляющим сервером. Такая система усиливает защищенность корпоративной подсети благодаря централизации информации об атаке от различных IDS.

dIDS состоит из следующих подсистем:

- центральный анализирующий сервер
- агенты сети
- сервер сбора информации об атаке.

Центральный анализирующий сервер обычно состоит из базы данных и Web-сервера, что позволяет сохранять информацию об атаках и манипулировать данными с помощью удобного Web-интерфейса.

Агент сети - один из наиболее важных компонентов dIDS. Он представляет собой небольшую программу, цель которой - сообщать об атаке на центральный анализирующий сервер.

Сервер сбора информации об атаке - часть системы dIDS, логически базирующаяся на центральном анализирующем сервере. Сервер определяет параметры, по которым группируется информация, полученная от агентов сети. Группировка может осуществляться по следующим параметрам:

- IP-адресу атакующего;
- порту получателя;
- номеру агента;
- дате, времени;
- протоколу;
- типу атаки и т. д.

Стандарт де-факто систем IDS – SNORT.

Snort является открытой Network Intrusion Detection/Prevention System (NIDS/NIPS) системой, позволяющей проводить анализ трафика в реальном времени, а также протоколирование пакетов в IP сетях. Он позволяет анализировать протоколы верхних уровней на предмет поиска и соответствия нужного содержимого и может использоваться для обнаружения различных атак. Snort использует гибкий язык написания правил, который позволяет охарактеризовать необычный трафик для сбора или анализа.

Коммерческие IDS (примеры) – StoneGate IPS, «ФОРПОСТ» версии 2.0, Cisco IPS 4240, IBM Proventia GX4004, StoneGate IPS 1060.

Системы Security Information and Event Management (SIEM)

Система обеспечения информационной безопасности предприятия может включать в себя множество компонентов, это и антивирусные продукты, и сетевые системы предотвращения вторжений, межсетевые экраны, системы контроля доступа к внешним устройствам и портам, системы предотвращения утечек конфиденциальной информации, впрочем и операционная система тоже содержит в себе не один встроенный механизм обеспечения ИБ. Это не полный список средств ИБ, множество разнообразных программно-аппаратных комплексов, находятся в постоянной активности "событие - действие - реакция"... И работают в полной, или частичной изоляции друг от друга.

Security Information and Event Management (SIEM) - решения для сбора и анализа событий, генерируемых различными типами СЗИ.

Задачи систем SIEM:

1. Консолидация и хранение журналов событий от различных источников — сетевых устройств, приложений, журналов ОС, средств защиты. Бывают ситуации, когда инцидент увидели поздно, а события уже давно затерты или журналы событий почему-либо недоступны, и причины инцидента выявить фактически невозможно. Кроме того, соединение с каждым источником и просмотр событий займет уйму времени. В противном случае, без анализа событий, есть риск узнать об инциденте в вашей компании из новостных лент.

2. Предоставление инструментов для анализа событий и разбора инцидентов. Форматы событий в различных источниках различаются. Текстовый формат при больших объемах сильно утомляет, снижает вероятность выявления инцидента. Часть продуктов класса SIEM унифицирует события и делает их более читабельными, а интерфейс визуализирует только важные информационные события, акцентирует на них внимание, позволяет отфильтровывать не критические события.
3. Корреляция и обработка по правилам. По одному событию не всегда можно судить об инциденте. Простейший пример — «login failed»: один случай ничего не значит, но три и более таких события с одной учетной записью уже могут свидетельствовать о попытках подбора. В простейшем случае в SIEM правила представлены в формате RBR (Rule Based Reasoning) и содержат набор условий, триггеры, счетчики, сценарий действий.

Автоматическое оповещение и инцидент-менеджмент. *Основная задача SIEM* — не просто собрать события, но автоматизировать процесс обнаружения инцидентов с документированием в собственном журнале или внешней системе HelpDesk, а также своевременно информировать о событиях.

SIEM способна выявлять:

- сетевые атаки во внутреннем и внешнем периметрах;
- вирусные эпидемии или отдельные вирусные заражения, не удаленные вирусы, бэкдоры и трояны;
- попытки несанкционированного доступа к конфиденциальной информации;
- фрод и мошенничество;
- ошибки и сбои в работе информационных систем;
- уязвимости;
- ошибки конфигураций в средствах защиты и информационных системах.

Система SIEM универсальна за счет своей логики. Но для того чтобы возложенные на нее задачи решались — необходимы полезные источники и правила корреляции. Любое событие (например, если в определенной комнате открылась дверь) может быть подано на вход SIEM и использовано

Источники выбираются на основании следующих факторов:

- критичность системы (ценность, риски) и информации (обрабатываемой и хранимой);
- достоверность и информативность источника событий;

- покрытие каналов передачи информации (должны учитываться не только внешний, но и внутренний периметр сети);
- решение спектра задач ИТ и ИБ (обеспечение непрерывности, расследование инцидентов, соблюдение политик, предотвращение утечек информации и т. п.).

Основные источники SIEM

1. Access Control, Authentication — для мониторинга контроля доступа к информационным системам и использования привилегий.
2. Журналы событий серверов и рабочих станций — для контроля доступа, обеспечения непрерывности, соблюдения политик информационной безопасности.
3. Сетевое активное оборудование (контроль изменений и доступ, счетчики сетевого трафика).
4. IDS\IPS. События о сетевых атаках, изменение конфигураций и доступ к устройствам.
5. Антивирусная защита. События о работоспособности ПО, базах данных, изменении конфигураций и политик, вредоносных программах.
6. Сканеры уязвимостей. Инвентаризация активов, сервисов, программного обеспечения, уязвимостей, поставка инвентаризационных данных и топологической структуры.
7. GRC-системы для учета рисков, критичности угрозы, определение приоритета инцидента.
8. Прочие системы защиты и контроля политик ИБ: DLP, антифрода, контроля устройств и т. п.
9. Системы инвентаризации и asset-management. С целью контроля активов в инфраструктуре и выявления новых.
10. Netflow и системы учета трафика.

Коммерческие SIEM-системы :

HP ArcSight,
IBM QRadar,
McAfee ESM,
Symantec SIM,
Cisco MARS,
GFI ESM.